

Marco integrativo GQM + PRAGMATIC para indicadores AMPARO-ENS

De los objetivos nacionales a los bits que cuentan

El propósito de este marco es asegurar que cada dato técnico recogido en el contexto ENS-INES-AMPARO responde a una pregunta clara y a un objetivo legítimo, y que además la métrica resultante supera el escrutinio PRAGMATIC (Predictiva, Relevante, Accionable, Genuina, Significativa, Precisa, Oportuna, Independiente y Rentable). [web:32][web:33][web:21]

1. Principios generales

1. Cada objetivo se formula en el contexto del Esquema Nacional de Seguridad (ENS) y de los objetivos de seguridad y ciberresiliencia del Estado. [web:30][web:3]
2. Cada objetivo se operacionaliza mediante una o varias preguntas GQM (Goal-Question-Metric). [web:32]
3. Cada pregunta se responde con una o más métricas, obtenidas de fuentes estructuradas (INES, AMPARO, herramientas de gestión, registros de incidentes, etc.). [web:21][web:39]
4. Cada métrica se evalúa con los nueve criterios PRAGMATIC para asegurar su utilidad práctica.

2. Objetivos ENS – INES – AMPARO y estructura GQM

Objetivo 1 (G1): Mejorar la adecuación y madurez ENS de las organizaciones

- Contexto ENS: RD 311/2022, art. 11, 12, Anexo II (medidas); guías CCN-STIC-815 y 824. [web:30][web:32][web:33]
- Intención: Asegurar que las medidas ENS están implantadas en el grado exigido por la categoría de los sistemas y que la organización progresa en el tiempo.

Preguntas GQM:

- Q1.1: ¿Qué porcentaje de medidas ENS relevantes están implantadas de forma efectiva?
- Q1.2: ¿Está actualizada la Declaración de Aplicabilidad (DA) y se corresponde con la realidad técnica?
- Q1.3: ¿Con qué frecuencia se revisa el estado de adecuación ENS?

Métricas ejemplo:

- M1.1: % de medidas ENS implantadas (por categoría y global).
- M1.2: Edad de la última revisión de la DA (meses).
- M1.3: Frecuencia de revisión de adecuación ENS (años).

Objetivo 2 (G2): Fortalecer la gestión de riesgos de ciberseguridad alineada con ENS

- Contexto ENS: art. 35 (evaluación de seguridad), Anexo I (categorías), MAGERIT/PILAR. [web:30][web:38]
- Intención: Disponer de análisis de riesgos actualizados que soporten decisiones de tratamiento y priorización de medidas.

Preguntas GQM:

- Q2.1: ¿Se utiliza una metodología formal de análisis de riesgos (por ejemplo, MAGERIT con PILAR)?
- Q2.2: ¿Con qué periodicidad se actualizan los análisis de riesgo de los sistemas ENS?
- Q2.3: ¿Existe un registro consolidado de riesgos con responsables y planes de tratamiento?

Métricas ejemplo:

- M2.1: Nivel de formalización de la metodología de riesgos (escala 0–3).
- M2.2: Antigüedad media de los análisis de riesgo (años).
- M2.3: % de riesgos críticos con plan de tratamiento asignado.

Objetivo 3 (G3): Avanzar hacia modelos de seguridad de tipo Zero Trust

- Contexto: ENS Anexo II (control de acceso, protección de redes), orientaciones Zero Trust de fabricantes líderes. [web:11][web:15][web:2]
- Intención: Reducir la dependencia del perímetro clásico y reforzar la autenticación, la segmentación y la verificación continua.

Preguntas GQM:

- Q3.1: ¿Qué porcentaje de accesos a sistemas críticos está protegido por MFA?
- Q3.2: ¿Cómo de granular es la segmentación de red (macro vs. microsegmentación)?
- Q3.3: ¿Se aplican controles de acceso basados en contexto (usuario, dispositivo, ubicación)?

Métricas ejemplo:

- M3.1: % de cuentas privilegiadas con MFA habilitado.
- M3.2: Índice de segmentación (número de segmentos relevantes / superficie total).
- M3.3: % de recursos protegidos por políticas de acceso condicional.

Objetivo 4 (G4): Incrementar la ciberresiliencia y la capacidad de continuidad de los servicios

- Contexto ENS: medidas de continuidad y recuperación (Anexo II), CCN-STIC-817 (gestión de incidentes), literatura sobre ciberresiliencia. [web:25][web:6][web:10]
- Intención: Asegurar que la organización puede resistir, responder y recuperarse de incidentes sin pérdida inaceptable de servicio.

Preguntas GQM:

- Q4.1: ¿Se miden y controlan los tiempos de detección y respuesta a incidentes (MTTD, MTTR)?
- Q4.2: ¿Existen BCP/DRP que contemplen explícitamente ciberincidentes, y se prueban?
- Q4.3: ¿Se cumplen los objetivos de tiempo de recuperación (RTO) y punto de recuperación (RPO)?

Métricas ejemplo:

- M4.1: MTTD promedio para incidentes críticos (horas).
- M4.2: N° de pruebas de BCP/DRP por año y % de éxito.
- M4.3: % de incidentes en que se cumplen RTO/RPO definidos.

Objetivo 5 (G5): Optimizar el uso de recursos y el ROI en ciberseguridad

- Contexto: métricas de recursos y coste en CCN-STIC-815; informes industriales de ciberseguridad. [web:32][web:8][web:13]
- Intención: Alinear inversiones con reducción de riesgo y mejora de indicadores.

Preguntas GQM:

- Q5.1: ¿Qué proporción del presupuesto TI se dedica a ciberseguridad?
- Q5.2: ¿Cómo evoluciona el coste de incidentes en relación con la inversión en controles?
- Q5.3: ¿Se dispone de modelos de ROI que vinculen proyectos de seguridad con reducción de impacto esperado?

Métricas ejemplo:

- M5.1: % de presupuesto TI dedicado a seguridad.
- M5.2: Coste anual estimado de incidentes (euros).
- M5.3: Ratio (coste incidentes evitados / inversión en controles).

Objetivo 6 (G6): Consolidar un sistema de métricas y cuadros de mando alineados con CCN-STIC-815/824

- Contexto: Guía de Métricas e Indicadores ENS (CCN-STIC-815) e Informe del Estado de la Seguridad (CCN-STIC-824). [web:32][web:33][web:35]
- Intención: Disponer de un sistema estable de indicadores que soporte el Informe INES y el Informe Nacional.

Preguntas GQM:

- Q6.1: ¿Existe un cuadro de mando de ciberseguridad basado en indicadores definidos?
- Q6.2: ¿Se utilizan las guías CCN-STIC-815 y 824 como referencia para diseñar métricas?
- Q6.3: ¿Con qué frecuencia se revisan y actualizan los indicadores?

Métricas ejemplo:

- M6.1: N° de indicadores de seguridad activos en el cuadro de mando.
- M6.2: Grado de alineamiento con CCN-STIC-815/824 (escala 0–3).
- M6.3: Frecuencia de revisión del catálogo de indicadores (meses).

3. Evaluación PRAGMATIC de las métricas (visión general)

Para cada métrica (Mx.y) se evalúan nueve criterios:

- P – Predictivo: ¿Ayuda a anticipar resultados futuros o solo describe el pasado?
- R – Relevante: ¿Está directamente vinculada al objetivo definido?
- A – Accionable: ¿Sugiere acciones claras cuando la métrica empeora o mejora?
- G – Genuino: ¿Refleja la realidad o es fácilmente manipulable?
- M – Significativo (Meaningful): ¿Es comprensible y significativa para las partes interesadas?
- P – Preciso (Precise): ¿La medición es consistente y suficientemente exacta?
- T – Oportuno (Timely): ¿Se obtiene a la velocidad adecuada para su uso?
- I – Independiente: ¿Está libre de conflictos de interés o sesgos obvios?
- C – Coste-efectivo (Cost-effective): ¿El coste de obtenerla es razonable respecto a su utilidad?

La matriz detallada se recoge en el documento específico de evaluación PRAGMATIC.

4. Integración con INES y AMPARO

- INES proporciona datos agregados sobre estado de medidas, incidentes, recursos y otros indicadores ENS. [web:21][web:39]
- AMPARO actúa como gestor de planes de adecuación, DA, evidencias y documentación, alimentando muchas de las métricas definidas (por ejemplo, implantación de medidas, revisión de DA, etc.). [web:21][web:39]

El marco GQM + PRAGMATIC se superpone a estos sistemas:

5. Identifica qué objetivos ENS se persiguen.
6. Traduce esos objetivos en preguntas y métricas concretas.
7. Determina qué datos se obtienen de INES, cuáles de AMPARO y cuáles de otros sistemas.
8. Filtra las métricas innecesarias (no PRAGMATIC) y refuerza las que añaden valor.

5. Uso recomendado

9. Seleccionar, para cada organización, el subconjunto de métricas más relevante según su perfil ENS (BÁSICA, MEDIA, ALTA). [web:30]
10. Evaluar las métricas con los criterios PRAGMATIC y descartar las que no superan un umbral mínimo.
11. Incorporar las métricas resultantes al cuadro de mando y a la autoevaluación ENS.
12. Revisar objetivos y métricas al menos anualmente, o en paralelo a revisiones ENS y del Informe INES.

Este marco no elimina la burocracia, pero al menos se asegura de que cada casilla marcada tenga una línea de continuidad visible desde el objetivo nacional hasta el log del sistema.